NETWORKWALKS CYBERSECURITY LAB

PENETRATION TESTING REPORT

MEDIROZA HOSPITAL

Black Box Web Application Security Assessment

Target	https://medirozahospital.com
Assessment Type	Authorized Black-Box Penetration Test
Conducted For	Networkwalks Cybersecurity Lab (Educational Engagement)
Prepared By	Gokul R | Batch B083
Classification	**CONFIDENTIAL — For Internal / Training Use Only**

Prepared by Gokul R • Batch B083 • Hindusthan College of Arts and Science
Cybersecurity (VAPT) Training Report • Networkwalks

1. Executive Summary

This report presents the findings of an authorized black-box penetration test conducted against the Mediroza Hospital web application (https://medirozahospital.com) as part of an educational cybersecurity lab engagement through Networkwalks. The assessment was carried out in a controlled training environment with written authorization and was scoped strictly to the target application.

The objective of the assessment was to identify security weaknesses across authentication mechanisms, application input handling, protected document (PDF) security, document metadata exposure, and forgotten or improperly secured server backups.

The assessment identified multiple security weaknesses, including a SQL injection vulnerability that permitted authentication bypass, weak password protection on confidential PDF reports, sensitive information disclosed through document metadata, directory listing misconfigurations, and the public exposure of a historical database backup containing confidential staff salary and shareholder information.

The most severe findings identified during this assessment were the SQL injection authentication bypass on the patient login portal, the public exposure of a database backup file, and the resulting disclosure of confidential staff and shareholder data. These issues, taken together, represent a critical risk to the confidentiality and integrity of Mediroza Hospital's systems and should be remediated as a priority.

2. Scope and Methodology

Target: https://medirozahospital.com

Assessment Type: Black-box penetration testing

Authorization: Written permission was granted for this educational security assessment

Methodology

Phase 1 – Reconnaissance

- Reviewed the application's robots.txt file.
- Identified /patient/, /staff/, and /old/ as disallowed (and therefore noteworthy) paths.
- Flagged /old/ as a potentially forgotten or legacy directory of interest.

Phase 2 – Authentication Testing

- Tested login behaviour with different usernames to observe application responses.
- Observed differing error messages returned for valid versus invalid usernames.
- Tested the login input fields for SQL injection.
- Confirmed that a crafted SQL injection payload allowed authentication to be bypassed.

Phase 3 – Restricted Content Access

- Accessed the patient "My Lab Reports" area following authentication bypass.
- Retrieved the three protected patient PDF reports made available in the portal.

Phase 4 – PDF Security Testing

- Analysed the encryption applied to the retrieved PDF files.
- Used John the Ripper with appropriate PDF hash support and wordlists to attempt password recovery.
- Successfully recovered the passwords protecting all three PDF files.

- Decrypted patient_report_3.pdf using qpdf with the recovered password.

Phase 5 – Metadata Analysis

- Used ExifTool to analyse the decrypted patient_report_3.pdf.
- Identified the document Author field value: j.malik.
- Identified a Comments field referencing a database backup that had been moved to /old prior to a site migration.

Phase 6 – Backup Exposure

- Confirmed the /old/ path via robots.txt.
- Accessed the /old/ directory directly.
- Confirmed that directory listing was enabled.
- Identified the publicly accessible file mediroza_db_backup_2019.sql.
- Downloaded the authorized lab backup file for analysis.
- Extracted only the staff and shareholder records required to demonstrate impact.

Tools Used

- Web browser
- Kali Linux
- curl
- John the Ripper
- qpdf
- ExifTool
- grep
- sed
- wget

Limitations

- Testing was restricted to the authorized lab scope.
- No social engineering, denial-of-service testing, or out-of-scope testing was performed.

3. Findings and Proof of Exploitation

Finding 1: Username Enumeration

Severity: Medium

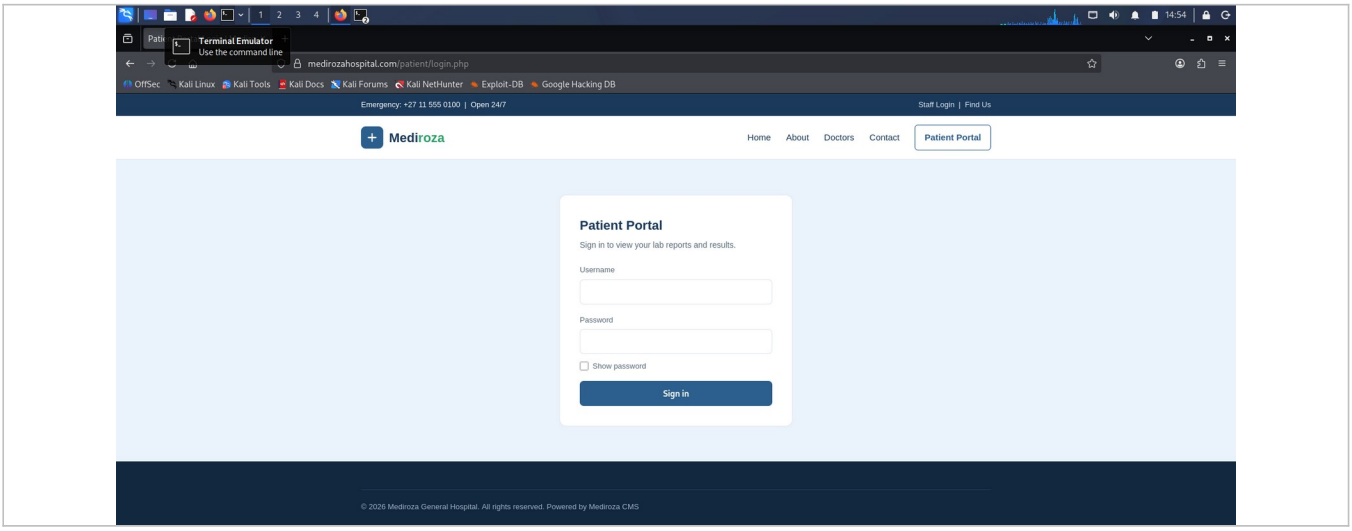
Affected Location: patient/login.php

Description

During authentication testing, the login page was found to return different responses depending on whether the submitted username existed in the system.

Evidence

The login page returned different responses for an invalid username compared to an existing username, allowing valid accounts to be distinguished from invalid ones. The baseline Patient Portal login interface used for this testing is shown below.



E01 — Patient Portal login interface used during authentication testing.

Impact

An attacker can use the differing responses to enumerate valid usernames, which materially simplifies subsequent brute-force or credential-stuffing attacks.

Recommendation

Return the same generic authentication error message for both invalid usernames and incorrect passwords, regardless of which field was incorrect.

Finding 2: SQL Injection Authentication Bypass

Severity: Critical

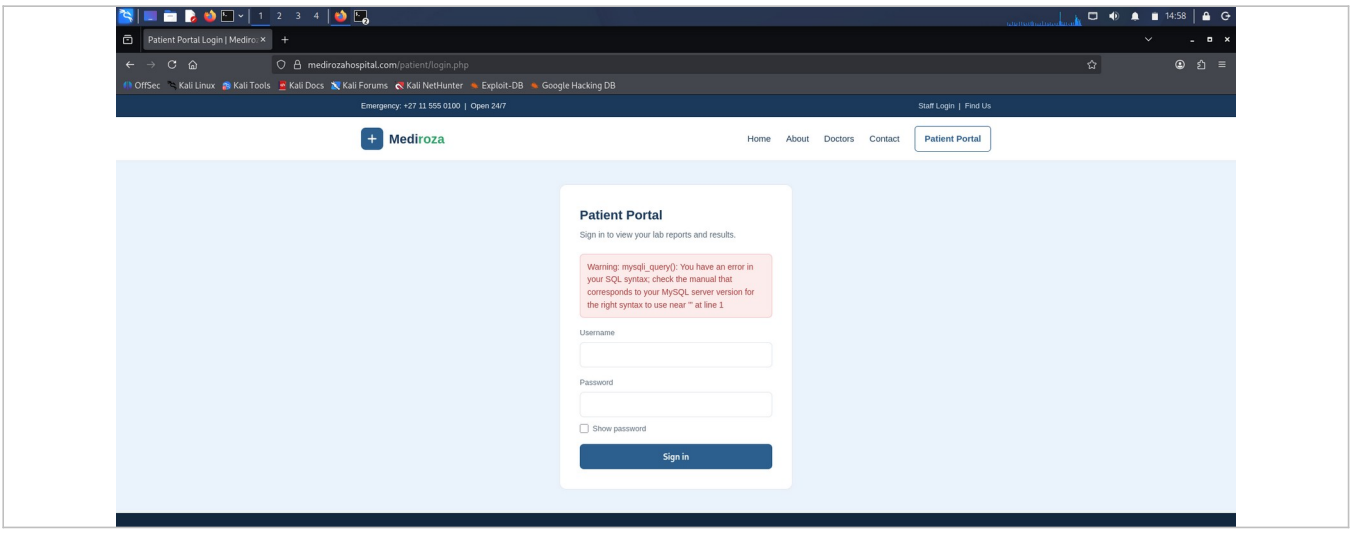
Affected Location: patient/login.php

Description

The login form's username field was found to be vulnerable to SQL injection. User-supplied input was concatenated directly into a backend SQL query without sanitization or parameterization.

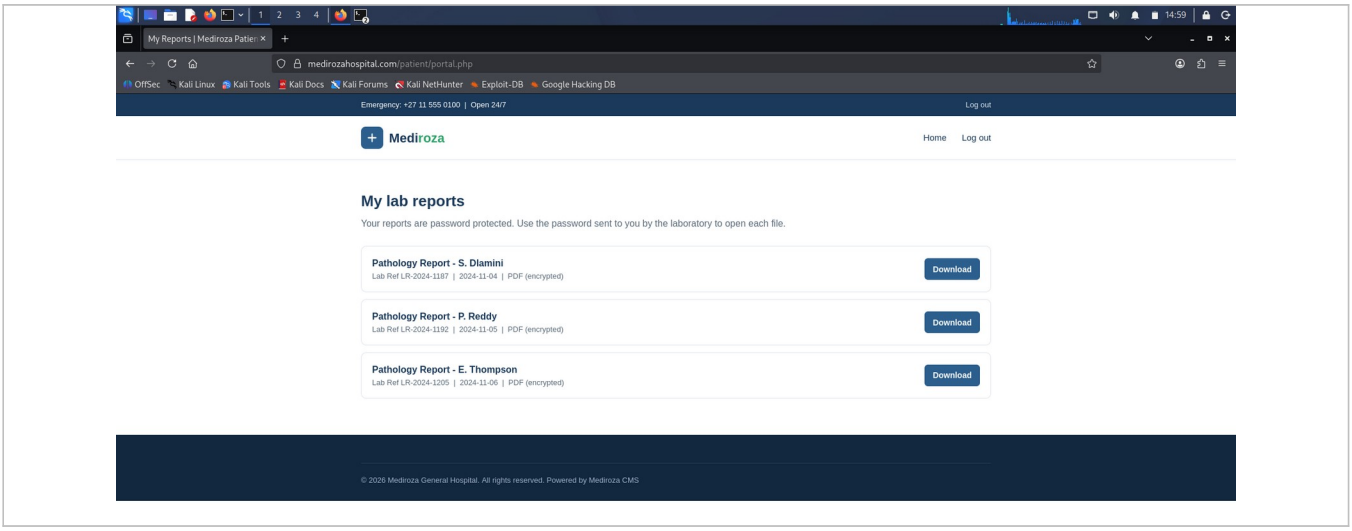
Evidence

A specially crafted username input triggered a MySQL syntax error, confirming that the application was vulnerable to SQL injection.



E02 — MySQL syntax error returned by patient/login.php following an SQL injection probe.

The authorized lab payload was subsequently used to demonstrate that authentication could be bypassed entirely, granting access to the "My Lab Reports" area without valid credentials.



E03 — Successful authentication bypass; the "My Lab Reports" page was reached without valid credentials.

Impact

Successful exploitation of this SQL injection vulnerability allowed access to restricted application functionality and protected patient documents without valid credentials, undermining the application's entire authentication control.

Recommendation

Use parameterized queries or prepared statements for all database interactions, and never construct SQL statements directly from unvalidated user input.

Finding 3: Protected PDF Reports Accessible After Authentication Bypass

Severity: High

Affected Location: patient/reports/

Description

Once the authentication mechanism was bypassed, three confidential patient PDF reports became accessible through the "My Lab Reports" page.

Evidence

The "My Lab Reports" page listed three password-protected patient pathology reports, each available for download without further authorization checks (see E03 above).

Impact

An attacker exploiting the authentication weakness could directly access protected patient documents that should only be reachable by the legitimate, authenticated patient.

Recommendation

Implement proper server-side authorization checks on every document request, independent of the login form, and store sensitive documents outside the public web root where possible.

Finding 4: Weak PDF Password Protection

Severity: High

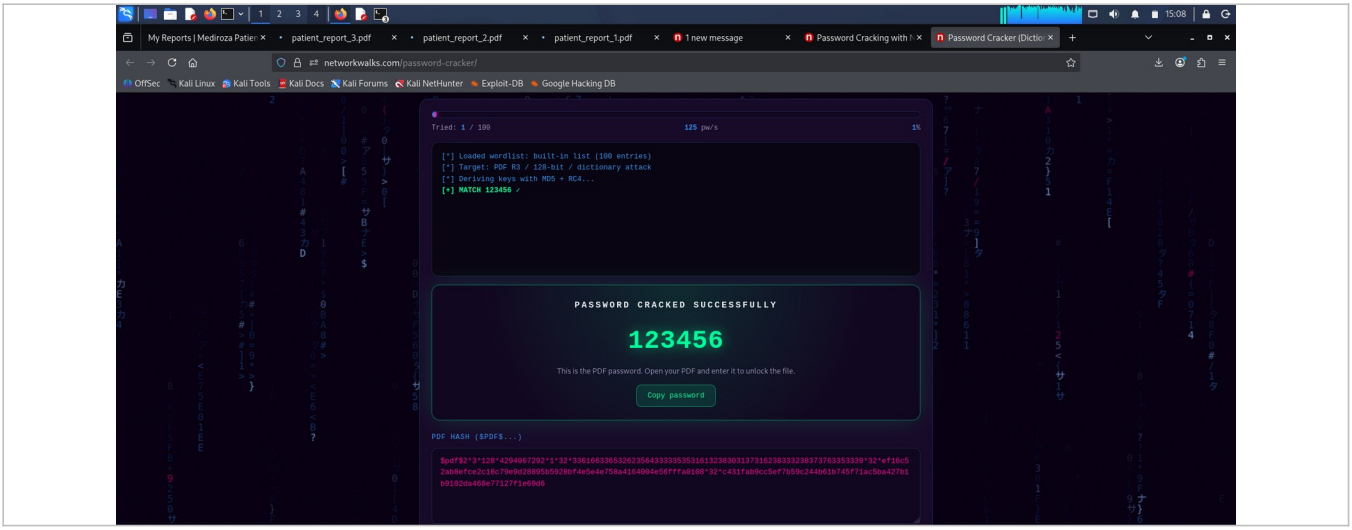
Affected Location: patient/reports/ (all three PDF reports)

Description

Each of the three retrieved PDF reports was protected with a password. These passwords were tested against a dictionary-based password recovery attack.

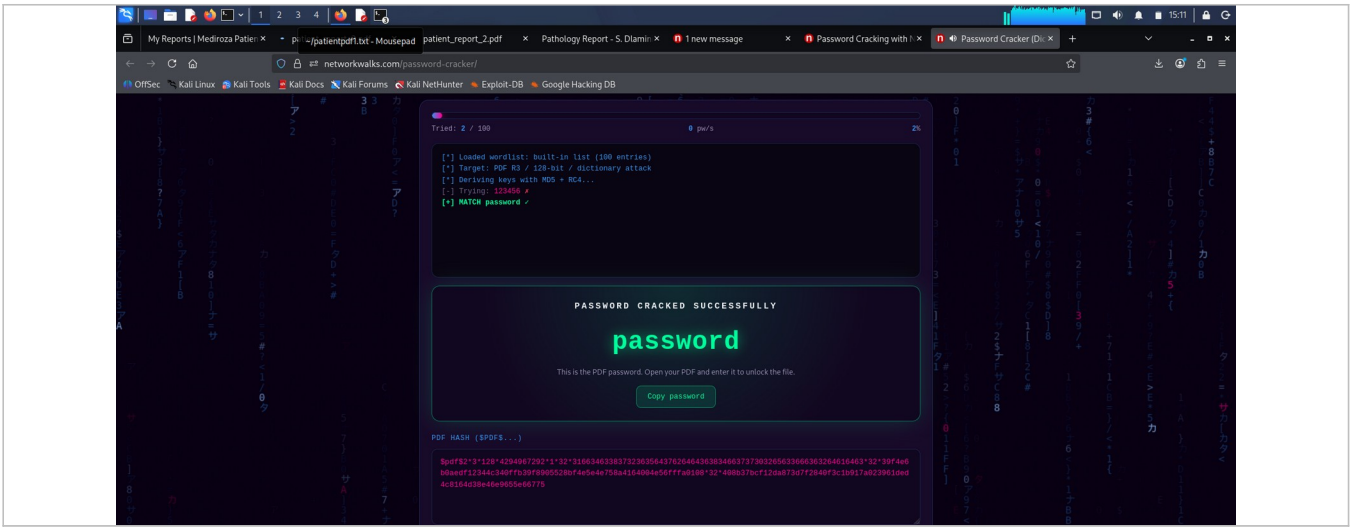
Evidence

The password protecting patient_report_1.pdf was recovered within seconds using a dictionary attack against the PDF's encryption hash.



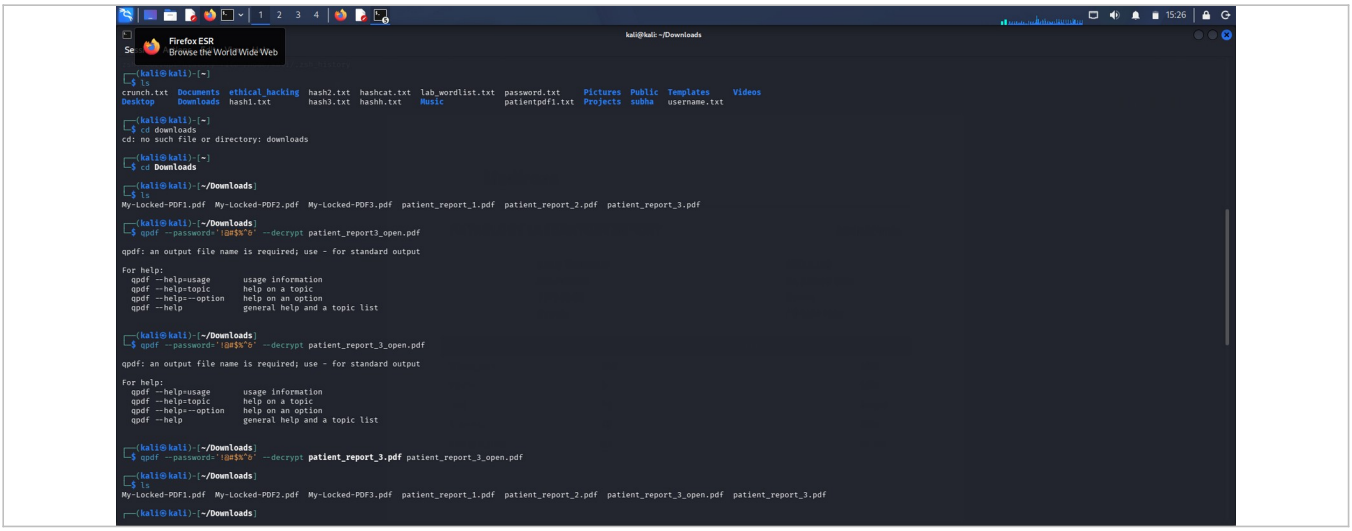
E05 — Password recovered for patient_report_1.pdf ("123456") via dictionary attack.

The password protecting patient_report_2.pdf was recovered using the same technique.



E06 — Password recovered for patient_report_2.pdf ("password") via dictionary attack.

For patient_report_3.pdf, the recovered password was used with qpdf to produce an unlocked copy of the file for authorized metadata analysis.



E07 — qpdf used to decrypt patient_report_3.pdf using the recovered password.

Impact

Weak, dictionary-guessable document passwords significantly reduce the effectiveness of PDF encryption and may allow unauthorized parties to open sensitive documents if the files are obtained through any means.

Recommendation

Use strong, unique, randomly generated passwords for protected documents, and consider stronger document protection mechanisms than password-only PDF encryption.

Finding 5: Sensitive PDF Metadata Exposure

Severity: Medium

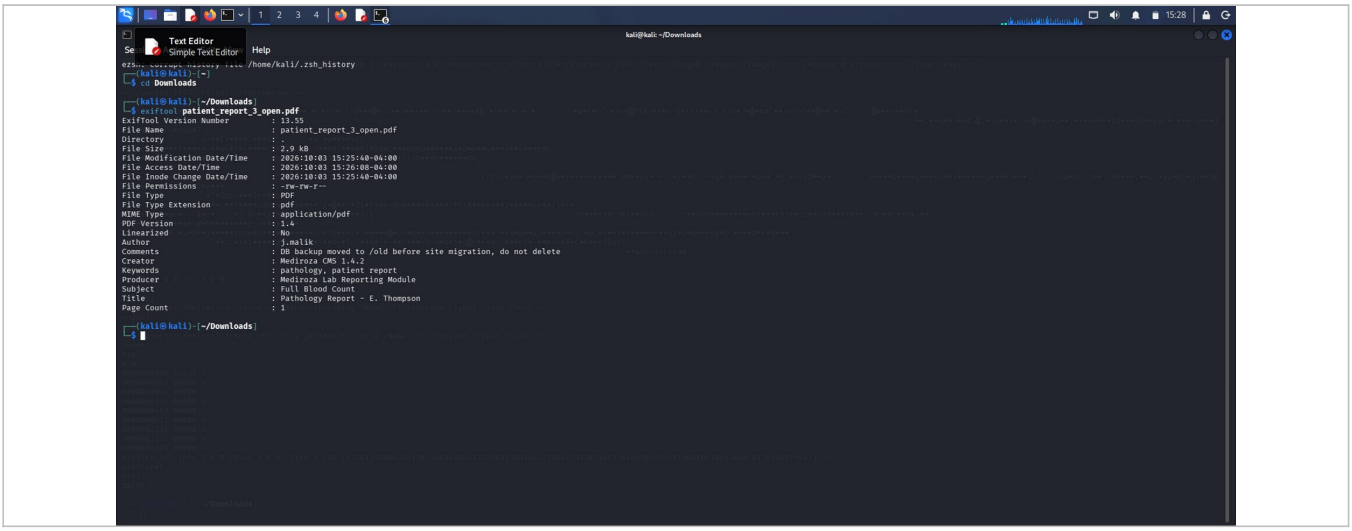
Affected File: patient_report_3.pdf

Description

Metadata embedded in the decrypted PDF file was found to contain internal information not intended for external disclosure.

Evidence

ExifTool analysis of the decrypted file revealed an Author field value of "j.malik" and a Comments field stating that a database backup had been moved to /old prior to a site migration, with an instruction not to delete it.



E08 — ExifTool metadata extracted from the decrypted patient_report_3.pdf, revealing the Author field and a Comments field referencing the /old backup location.

Impact

The exposed metadata disclosed internal operational information that directly contributed to identifying a forgotten server directory, which in turn led to the discovery of an exposed database backup (see Finding 6).

Recommendation

Remove unnecessary metadata (author information, internal comments, software/version details) from documents before they are distributed to patients or external parties.

Finding 6: Forgotten Backup Directory and Directory Listing

Severity: Critical

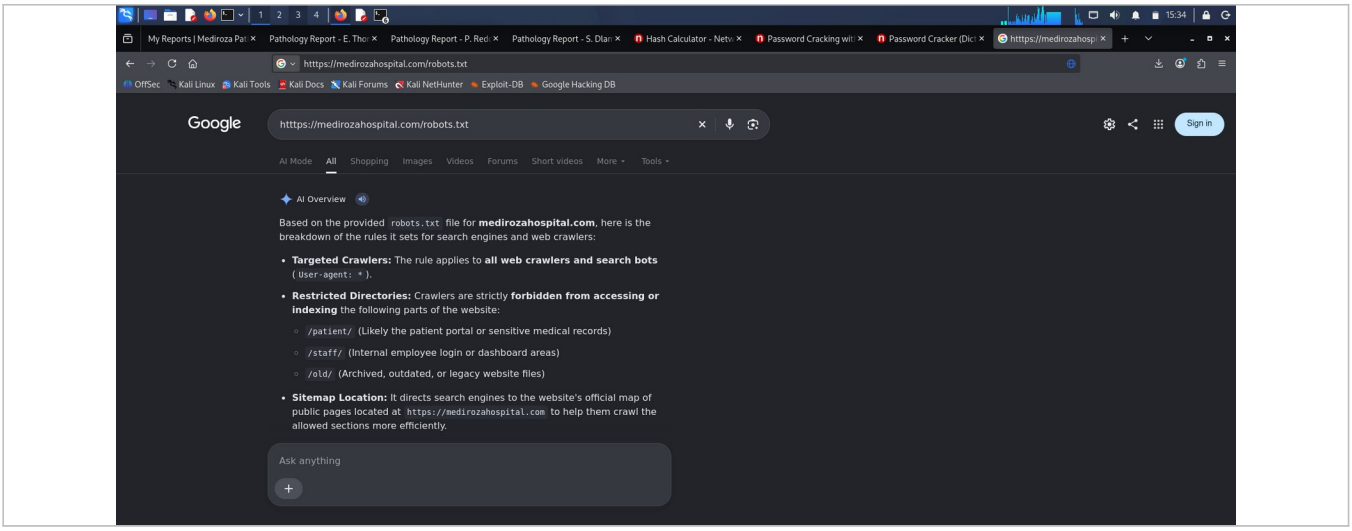
Affected Location: /old/

Description

Following the metadata clue identified in Finding 5, the /old/ directory referenced in robots.txt was examined directly.

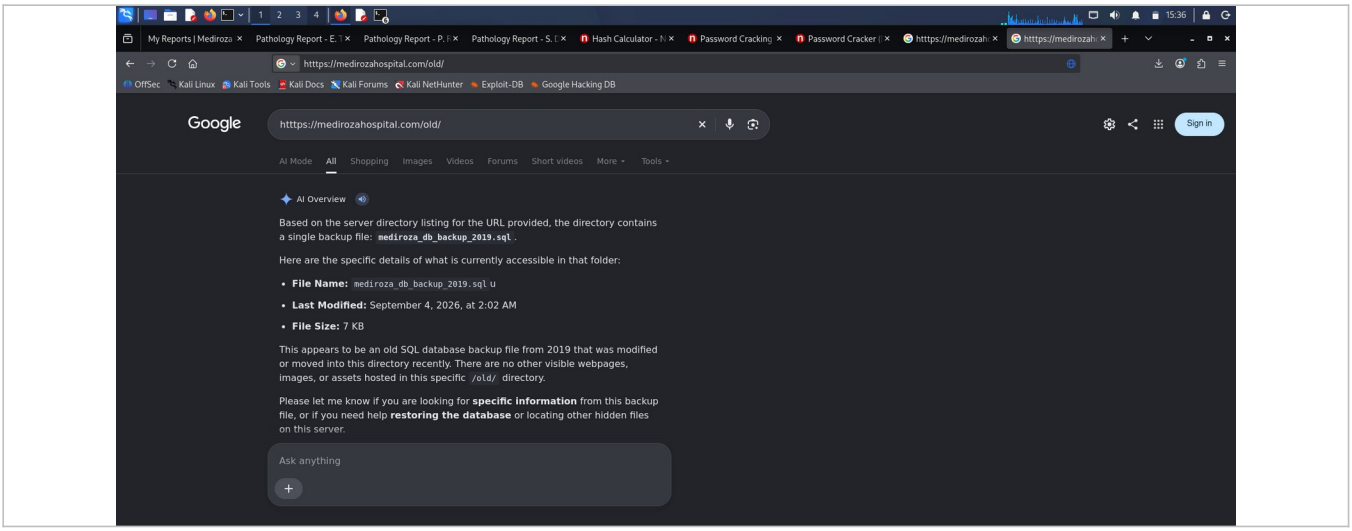
Evidence

The application's robots.txt file confirmed the existence of the /patient/, /staff/, and /old/ paths, with /old/ flagged as containing archived or legacy website files.



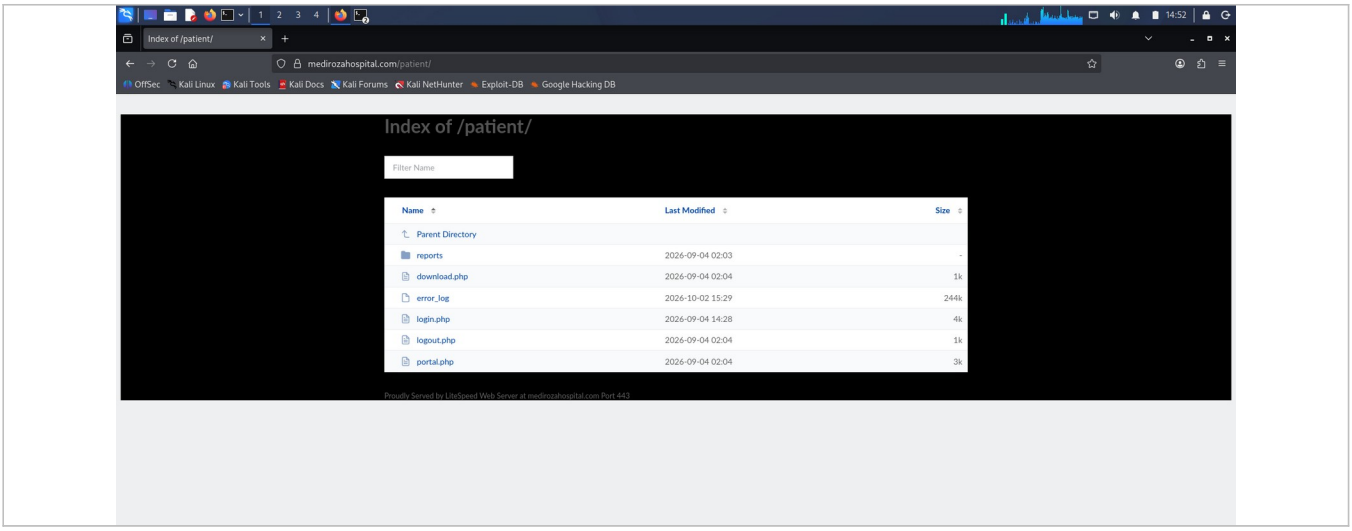
E09 — robots.txt disallow entries confirming the existence of /patient/, /staff/, and /old/.

The /old/ directory was found to be directly accessible, with directory listing enabled, exposing a single file: mediroza_db_backup_2019.sql.



E10 — Directory listing of /old/, exposing the publicly accessible backup file mediroza_db_backup_2019.sql.

Directory listing misconfiguration was also observed elsewhere on the application; the /patient/ directory similarly exposed its underlying application files (including login.php, portal.php, and an error_log file) when browsed directly, indicating the issue is not isolated to a single directory.



E11 — Directory listing enabled on /patient/, exposing application source files and an error_log file.

Impact

A publicly accessible database backup can expose highly sensitive organizational information and may provide an attacker with significant additional attack paths, including credential material, schema details, and confidential records.

Recommendation

Disable directory listing across the web server, remove obsolete backups and legacy files from publicly accessible directories, store backups outside the web root, and enforce appropriate access controls on all server directories.

Finding 7: Confidential Staff Salary and Shareholder Data Exposure

Severity: Critical

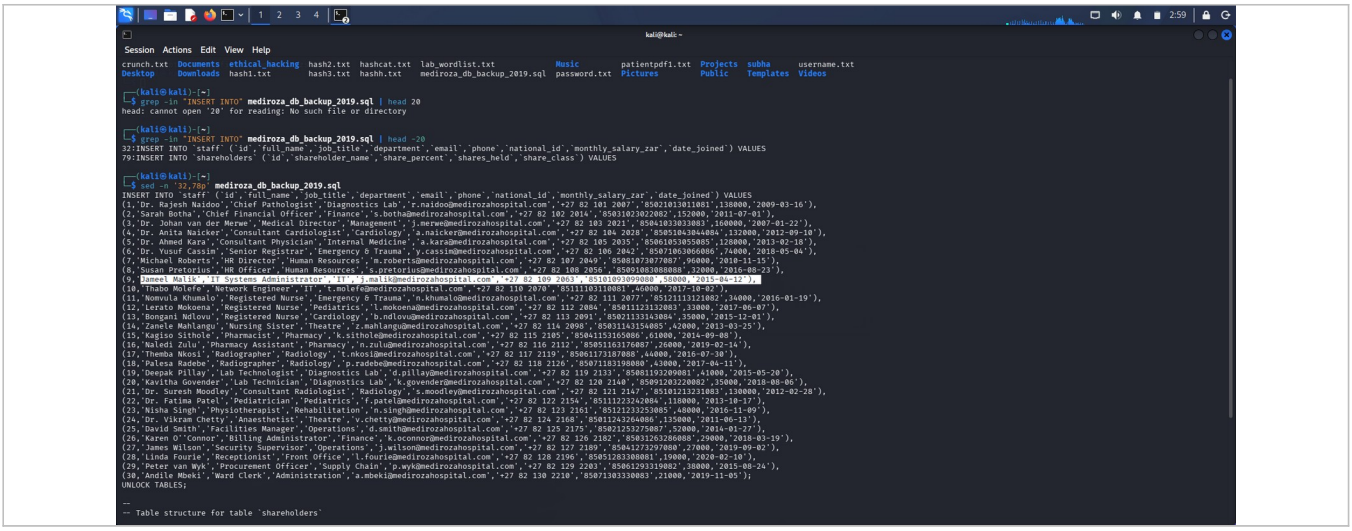
Affected File: mediroza_db_backup_2019.sql

Description

The exposed SQL backup file was found to contain complete staff and shareholder records, including confidential compensation and ownership information.

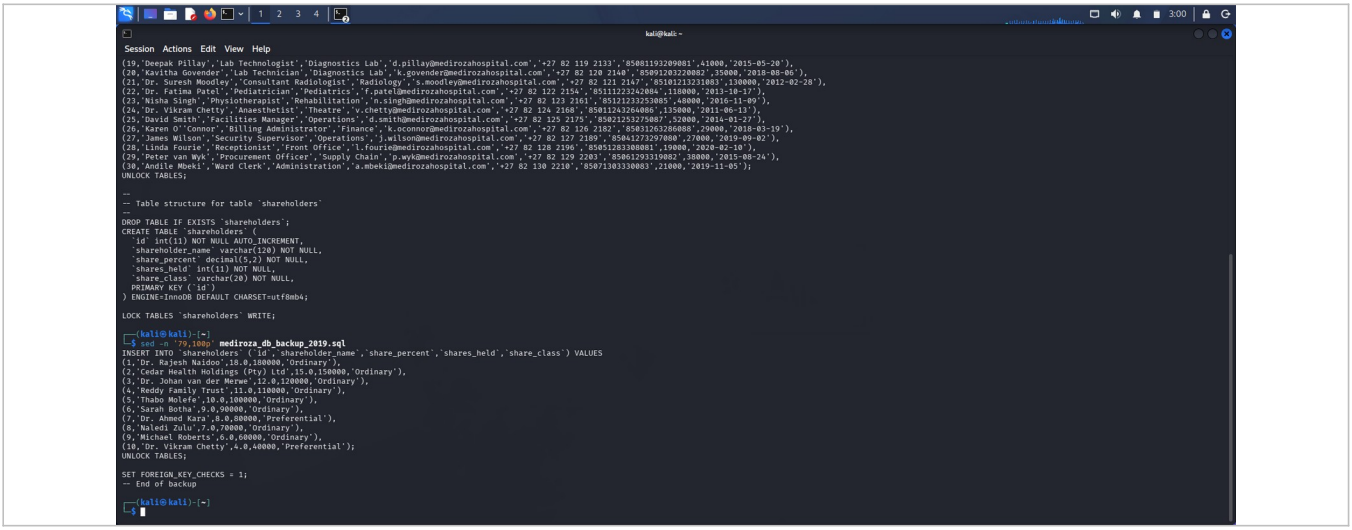
Evidence

The staff table within the backup contained full employee records, including job titles, departments, contact details, national ID numbers, and monthly salaries. Notably, the record for "Jameel Malik" (IT Systems Administrator, IT Department, monthly salary 58,000 ZAR) corresponds to the email address and author initials "j.malik" identified in the PDF metadata in Finding 5, directly linking the metadata clue to the exposed database.



E12 — Staff records extracted from mediroza_db_backup_2019.sql, including the record matching the "j.malik" metadata author.

The shareholders table within the same backup contained shareholder names, shareholding percentages, number of shares held, and share class — commercially sensitive ownership data with no legitimate reason to be publicly accessible.



E13 — Shareholder records extracted from mediroza_db_backup_2019.sql.

Impact

Exposure of confidential employee salary information and shareholder ownership data represents a significant confidentiality breach, with potential legal, regulatory, financial, and reputational consequences for Mediroza Hospital.

Recommendation

Remove database backups from publicly accessible directories, restrict backup access to authorized personnel only, encrypt backups at rest, implement proper access controls, and conduct regular audits of web-accessible files and directories.

4. Risk Rating Summary

#	Finding	Severity
1	Username Enumeration	Medium
2	SQL Injection Authentication Bypass	Critical
3	Protected PDF Reports Accessible After Login Bypass	High
4	Weak PDF Passwords	High
5	Sensitive PDF Metadata Exposure	Medium
6	Forgotten Backup Directory / Directory Listing	Critical
7	Confidential Staff Salary and Shareholder Data Exposure	Critical

5. Recommendations and Remediation

1. Authentication

- Use generic authentication error messages that do not reveal whether a username or password was incorrect.
- Implement account lockout, rate limiting, or CAPTCHA controls to mitigate brute-force and enumeration attacks.

2. SQL Injection

- Use parameterized queries or prepared statements for all database interactions.
- Validate and safely handle all user input on both the client and server sides.

3. PDF Access Control

- Enforce server-side authorization on every request to sensitive documents.
- Do not expose sensitive documents directly through predictable public paths.

4. PDF Password Security

- Use strong, unique, randomly generated passwords for protected documents.
- Adopt stronger document encryption mechanisms where feasible.

5. Metadata

- Remove unnecessary metadata from sensitive documents prior to distribution.

6. Backup Security

- Disable directory listing on all web-accessible directories.
- Remove old and unused backups from public web directories.

- Store backups outside the web root.
- Restrict backup access using authentication and authorization controls.
- Encrypt backups at rest.

7. Data Protection

- Apply least-privilege access controls across the application and infrastructure.
- Regularly audit exposed files and directories.
- Monitor for accidental data exposure on an ongoing basis.

6. Conclusion

This authorized penetration test identified multiple security weaknesses across Mediroza Hospital's patient portal, spanning authentication controls, document security, metadata handling, and backup exposure.

The most significant risks identified during this assessment were the SQL injection authentication bypass on the login portal, the publicly accessible database backup file, and the resulting exposure of confidential staff salary and shareholder information.

Remediation efforts should prioritize the Critical-rated findings first, followed by the High and then Medium-rated findings, in order to reduce the organization's overall risk exposure as quickly and effectively as possible.

7. Evidence Index

Evidence ID	Description
E01	Patient Portal login interface (baseline, pre-exploitation)
E02	MySQL syntax error returned by login.php, confirming SQL injection
E03	Successful authentication bypass — "My Lab Reports" page reached without valid credentials
E04	Three protected patient PDF reports listed and downloadable after bypass
E05	John the Ripper result — password recovered for patient_report_1.pdf ("123456")
E06	John the Ripper result — password recovered for patient_report_2.pdf ("password")
E07	qpdf decryption of patient_report_3.pdf using recovered password
E08	ExifTool metadata extracted from decrypted patient_report_3.pdf (Author: j.malik; Comment referencing /old/ backup)
E09	Google-cached confirmation of robots.txt disallow entries (/patient/, /staff/, /old/)
E10	Confirmation of exposed backup file mediroza_db_backup_2019.sql inside /old/
E11	Directory listing enabled on /patient/, exposing application source files and error_log
E12	Staff salary records extracted from mediroza_db_backup_2019.sql, including j.malik/Jameel Malik
E13	Shareholder records extracted from mediroza_db_backup_2019.sql